

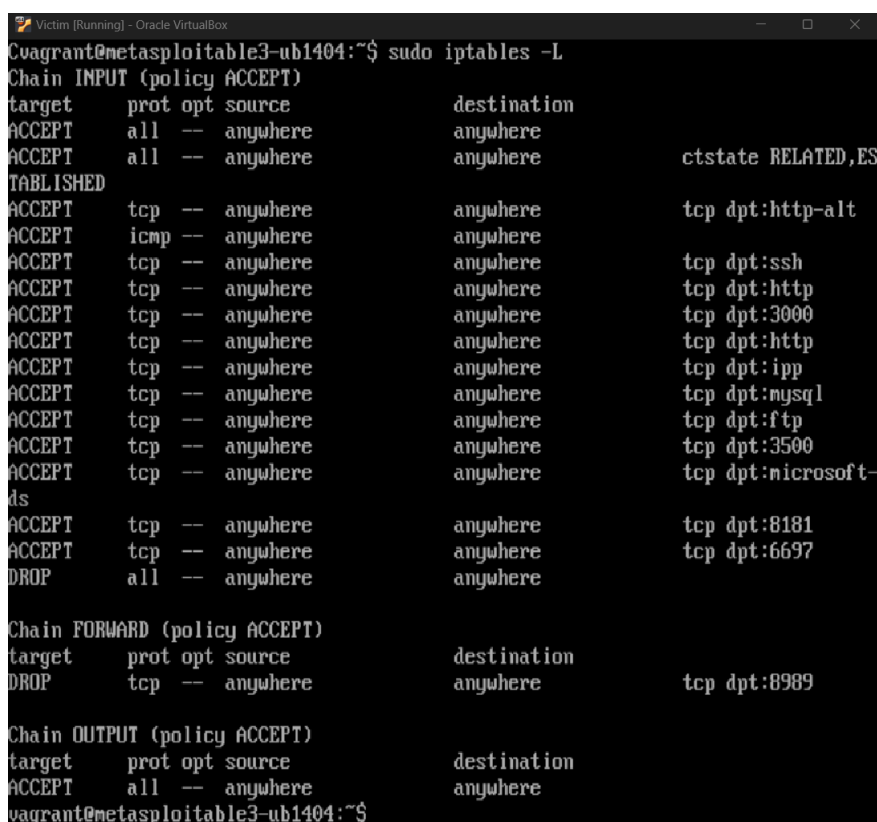
Phase 3 : Defensive Strategy Proposal

We implemented firewall rules using **iptables** to protect the SSH service against brute-force attacks. We documented the process with **before** and **after** screenshots to demonstrate the effectiveness of the defense.

1. Initial Firewall Status (BEFORE Defense)

We checked the existing firewall configuration with the following command:

```
sudo iptables -L
```



```

Victim [Running] - Oracle VirtualBox
vagrant@metasploitable3-ub1404:~$ sudo iptables -L
Chain INPUT (policy ACCEPT)
target     prot opt source                destination
ACCEPT     all  --  anywhere              anywhere
ACCEPT     all  --  anywhere              anywhere           ctstate RELATED,ESTABLISHED
ACCEPT     tcp  --  anywhere              anywhere             tcp dpt:http-alt
ACCEPT     icmp --  anywhere              anywhere
ACCEPT     tcp  --  anywhere              anywhere             tcp dpt:ssh
ACCEPT     tcp  --  anywhere              anywhere             tcp dpt:http
ACCEPT     tcp  --  anywhere              anywhere             tcp dpt:3000
ACCEPT     tcp  --  anywhere              anywhere             tcp dpt:http
ACCEPT     tcp  --  anywhere              anywhere             tcp dpt:ipp
ACCEPT     tcp  --  anywhere              anywhere             tcp dpt:mysql
ACCEPT     tcp  --  anywhere              anywhere             tcp dpt:ftp
ACCEPT     tcp  --  anywhere              anywhere             tcp dpt:3500
ACCEPT     tcp  --  anywhere              anywhere             tcp dpt:microsoft-
ds
ACCEPT     tcp  --  anywhere              anywhere             tcp dpt:8181
ACCEPT     tcp  --  anywhere              anywhere             tcp dpt:6697
DROP       all  --  anywhere              anywhere

Chain FORWARD (policy ACCEPT)
target     prot opt source                destination
DROP      tcp  --  anywhere              anywhere             tcp dpt:8989

Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination
ACCEPT    all  --  anywhere              anywhere
vagrant@metasploitable3-ub1404:~$ _

```

The initial configuration showed that SSH connections were **allowed from anywhere** without any restriction.

Attack Attempt BEFORE Defense

```
(attacker@attacker)-[~] /usr/share/ansible/roles/ubuntu/pool/universe/f/fail2ban/fail2ban
$ ./ssh_attack.sh 1000000
Trying user:vagrant
Permission denied, please try again.
Trying user:user
Permission denied, please try again.
Trying user:msfadmin
Permission denied, please try again.
Trying user:postgres
Permission denied, please try again.
Trying user:service
Permission denied, please try again.
Trying user:vagrant123
Permission denied, please try again.
Trying user:user123
Permission denied, please try again.
Trying user:msfadmin123
Permission denied, please try again.
Trying user:postgres123
Permission denied, please try again.
Trying user:service123
Permission denied, please try again.
Trying msfadmin:vagrant
Permission denied, please try again.
Trying msfadmin:user
Permission denied, please try again.
Trying msfadmin:msfadmin
Permission denied, please try again.
Trying msfadmin:postgres
Permission denied, please try again.
Trying msfadmin:service
Permission denied, please try again.
Trying msfadmin:vagrant123
Permission denied, please try again.
Trying msfadmin:user123
Permission denied, please try again.
Trying msfadmin:msfadmin123
Permission denied, please try again.
Trying msfadmin:postgres123
Permission denied, please try again.
Trying msfadmin:service123
Permission denied, please try again.
Trying service:vagrant
Permission denied, please try again.
Trying service:user
Permission denied, please try again.
Trying service:msfadmin
Permission denied, please try again.
Trying service:postgres
Permission denied, please try again.
Trying service:service
Permission denied, please try again.
Trying service:vagrant123
Permission denied, please try again.
Trying service:user123
Permission denied, please try again.
Trying service:msfadmin123
Permission denied, please try again.
Trying service:postgres123
Permission denied, please try again.
Trying service:service123
Permission denied, please try again.
Trying vagrant:vagrant
✓ Success: vagrant:vagrant
```

2. Defense Implementation: Blocking Brute-Force SSH Attempts

We added iptables rules to limit SSH connection attempts:

Allow existing connections:

```
sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
```

```
vagrant@metasploitable3-ub1404:~$ sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
```

Track SSH connection attempts:

```
sudo iptables -A INPUT -p tcp --dport 22 -m state --state NEW -m recent --set
```

```
vagrant@metasploitable3-ub1404:~$ sudo iptables -A INPUT -p tcp --dport 22 -m state --state NEW -m recent --set
vagrant@metasploitable3-ub1404:~$ sudo iptables -A INPUT -p tcp --dport 22 -m st
```

Block if more than 2 attempts in 10 seconds:

```
sudo iptables -A INPUT -p tcp --dport 22 -m state --state NEW -m recent --update --seconds 10 --hitcount 3 -j DROP
```

```
vagrant@metasploitable3-ub1404:~$ sudo iptables -A INPUT -p tcp --dport 22 -m state --state NEW -m recent --update --seconds 10 --hitcount 3 -j DROP
```

Allow SSH under threshold:

```
sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT
```

```
vagrant@metasploitable3-ub1404:~$ sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT
```

3. Verification of Rules (AFTER Defense)

We verified the rules with:

```
sudo iptables -L -n -v --line-numbers
```

```
vagrant@metasploitable3-ub1404:~$ sudo iptables -L -n -v --line-numbers
Chain INPUT (policy ACCEPT 28 packets, 4491 bytes)
num  pkts bytes target    prot opt in     out     source    destina
tion
1    2102 383K ACCEPT    all  --  *      *       0.0.0.0/0  0.0.0.0
/0      state RELATED,ESTABLISHED
2      0    0      tcp  --  *      *       0.0.0.0/0  0.0.0.0
/0      tcp dpt:22 state NEW recent: SET name: DEFAULT side: source mask:
255.255.255.255
3      0    0 DROP      tcp  --  *      *       0.0.0.0/0  0.0.0.0
/0      tcp dpt:22 state NEW recent: UPDATE seconds: 10 hit_count: 3 name:
DEFAULT side: source mask: 255.255.255.255
4      0    0 ACCEPT    tcp  --  *      *       0.0.0.0/0  0.0.0.0
/0      tcp dpt:22

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
num  pkts bytes target    prot opt in     out     source    destina
tion

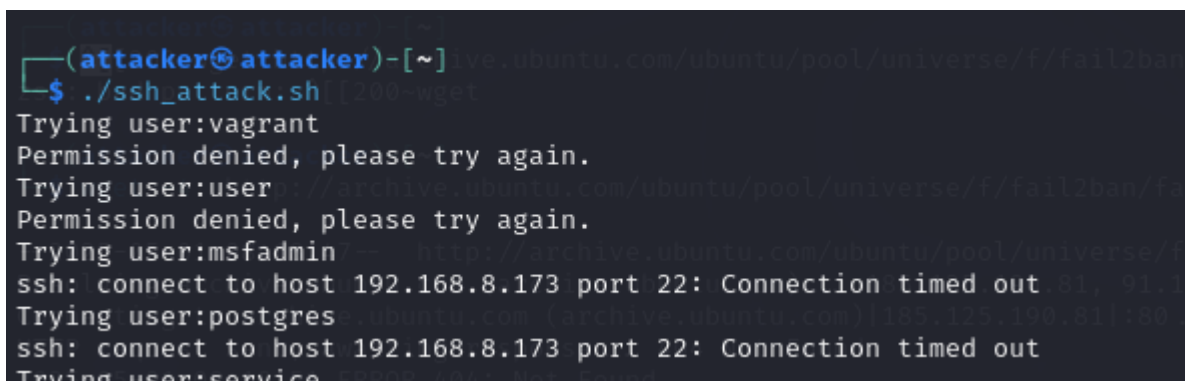
Chain OUTPUT (policy ACCEPT 356 packets, 78830 bytes)
num  pkts bytes target    prot opt in     out     source    destina
tion
```

The rules confirm that tracking and blocking for SSH brute-force attempts were added successfully.

4. Attack Attempt AFTER Defense

We reran the attack script after applying the firewall defense:

```
./ssh_attack.sh
```



```
(attacker@attacker)-[~] ve.ubuntu.com/ubuntu/pool/universe/f/fail2ban
$ ./ssh_attack.sh [200-wget]
Trying user:vagrant
Permission denied, please try again.
Trying user:user
Permission denied, please try again.
Trying user:msfadmin
ssh: connect to host 192.168.8.173 port 22: Connection timed out 81, 91.1
Trying user:postgres
ssh: connect to host 192.168.8.173 port 22: Connection timed out
Trying user:service
```

The result shows:

- First 2 attempts: allowed to try password
- Subsequent attempts: **connection timed out (blocked)**

Conclusion:

- We successfully implemented iptables rules to mitigate brute-force SSH attacks by limiting attempts to 2 tries within 10 seconds.
- The attack script demonstrated the defense was effective—further attempts from the attacker IP were **blocked** after reaching the threshold.
- This defensive mechanism strengthens SSH access control while still allowing legitimate users within a reasonable threshold.